

Remediation Guide

Vulnerability remediation plan

Report Type	Remediation
Tool Source	CrowdStrike
Reporting Month	July 2026

Table of Contents

- 1. Portfolio Risk Overview
- 2. Remediation Actions
- 3. Validation Requirements
- 4. References

1. Portfolio Risk Overview

Tool Source: CrowdStrike

Reporting Month: July 2026

Total Open Findings: 120

2. Remediation Actions

1. Google Chrome use-after-free vulnerability

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-001.corp.example, cs-asset-003.corp.example, cs-asset-006.corp.example, cs-asset-011.corp.example, cs-asset-014.corp.example
- CVE: CVE-2024-4671
- Severity: Critical
- Patch Priority: P1
- Advisory: <https://chromereleases.googleblog.com/>
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2024-4671>

Remediation steps:

1. Update Google Chrome to the latest enterprise stable release and relaunch the browser. Patch Google Chrome during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
winget upgrade --id Google.Chrome --exact --silent --accept-source-agreements --accept-package-agreements  
(Get-Item 'C:\Program Files\Google\Chrome\Application\chrome.exe').VersionInfo.FileVersion
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

2. Windows Remote Desktop Licensing Service remote code execution

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-002.corp.example, cs-asset-005.corp.example, cs-asset-007.corp.example, cs-asset-010.corp.example, cs-asset-015.corp.example
- CVE: CVE-2024-38077
- Severity: Critical
- Patch Priority: P1

- Advisory: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-38077>

- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2024-38077>

Remediation steps:

1. Install the current Microsoft cumulative security update and restart the affected host. Patch Microsoft Windows Server during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
Get-HotFix | Sort-Object InstalledOn -Descending | Select-Object -First 10
# Install the approved Microsoft security update and reboot if required
Get-Service TermServLicensing
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

3. Cisco IOS XE web UI privilege escalation

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-002.corp.example, cs-asset-004.corp.example, cs-asset-007.corp.example, cs-asset-012.corp.example, cs-asset-015.corp.example
- CVE: CVE-2023-20198
- Severity: High
- Patch Priority: P1
- Advisory:
<https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-privesc-j22SaA4z>
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2023-20198>

Remediation steps:

1. Install the fixed Cisco IOS XE release and disable the HTTP server when it is not required. Patch Cisco IOS XE during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
show version
show running-config | include ^ip http
# Stage and activate the vendor-fixed IOS XE image under the approved network change
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

4. Apache Log4j remote code execution

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-003.corp.example, cs-asset-008.corp.example, cs-asset-011.corp.example, cs-asset-016.corp.example, cs-asset-019.corp.example
- CVE: CVE-2021-44228
- Severity: High
- Patch Priority: P1
- Advisory: <https://logging.apache.org/log4j/2.x/security.html>
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2021-44228>

Remediation steps:

1. Upgrade Log4j to a vendor-supported fixed release and restart the application service. Patch Apache Log4j during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
find /opt -name 'log4j-core-*.jar' -print  
# Replace the vulnerable JAR through the approved application release  
sudo systemctl restart <affected-service>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

5. OpenSSL X.400 address type confusion

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-001.corp.example, cs-asset-004.corp.example, cs-asset-009.corp.example, cs-asset-012.corp.example, cs-asset-017.corp.example
- CVE: CVE-2023-0286
- Severity: Medium
- Patch Priority: P2
- Advisory: <https://www.openssl.org/news/secadv/20230207.txt>
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2023-0286>

Remediation steps:

1. Apply the operating-system vendor OpenSSL package update and restart dependent services. Patch OpenSSL during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
openssl version -a
sudo apt-get update
sudo apt-get install --only-upgrade openssl
sudo systemctl restart <affected-service>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

6. Linux kernel netfilter use-after-free

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-003.corp.example, cs-asset-005.corp.example, cs-asset-008.corp.example, cs-asset-013.corp.example, cs-asset-016.corp.example
- CVE: CVE-2024-1086
- Severity: Medium
- Patch Priority: P2
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2024-1086>

Remediation steps:

1. Install the distribution kernel security update and reboot into the fixed kernel. Patch Linux Kernel during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
uname -r
sudo apt-get update
sudo apt-get install --only-upgrade linux-image-generic
sudo reboot
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

7. Microsoft Exchange privilege escalation

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-001.corp.example, cs-asset-004.corp.example, cs-asset-006.corp.example, cs-asset-009.corp.example, cs-asset-014.corp.example
- CVE: CVE-2024-21410
- Severity: Low
- Patch Priority: P2
- Advisory: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-21410>
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2024-21410>

Remediation steps:

1. Install the supported Exchange Server security update and verify Extended Protection configuration. Patch Microsoft Exchange Server during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
Get-ExchangeServer | Format-List Name, Edition, AdminDisplayVersion
# Install the approved Exchange Security Update and reboot if required
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

8. Apache Tomcat AJP file read and inclusion

- Affected Findings: 15 across 15 assets
- Asset Examples: cs-asset-002.corp.example, cs-asset-005.corp.example, cs-asset-010.corp.example, cs-asset-013.corp.example, cs-asset-018.corp.example
- CVE: CVE-2020-1938
- Severity: Low
- Patch Priority: P2
- Advisory: <https://tomcat.apache.org/security-9.html>
- Advisory: <https://nvd.nist.gov/vuln/detail/CVE-2020-1938>

Remediation steps:

1. Upgrade Apache Tomcat, disable unused AJP connectors, and require a connector secret. Patch Apache Tomcat during the approved change window and capture validation evidence. Apply the minimum vendor-supported fixed release. Test in pre-production, deploy, restart if required, and run a verification scan.
2. Validate application and service health after the change.

3. Run a follow-up vulnerability scan and retain evidence.

```
/opt/tomcat/bin/version.sh
grep -n 'Connector.*AJP' /opt/tomcat/conf/server.xml
# Upgrade Tomcat and disable unused AJP or require a secret
sudo systemctl restart tomcat
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

3. Validation Requirements

Confirm service health, review change evidence, and verify closure in a follow-up vulnerability scan.

4. References

- <https://chromereleases.googleblog.com/>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-4671>
- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-38077>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-38077>
- <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-iosxe-webui-privesc-j22SaA4z>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-20198>
- <https://logging.apache.org/log4j/2.x/security.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2021-44228>
- <https://www.openssl.org/news/secadv/20230207.txt>
- <https://nvd.nist.gov/vuln/detail/CVE-2023-0286>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-1086>
- <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-21410>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-21410>
- <https://tomcat.apache.org/security-9.html>
- <https://nvd.nist.gov/vuln/detail/CVE-2020-1938>